

Passkeys: The hype vs. Reality

Are we there yet?



Microsoft



TD SYNEX



Capgemini



inforcenter



DELL
Technologies



nerdio



Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network



INSPARK



cegeka



Jan Bakker

IAM Consultant | MVP



Ronny de Jong

Security Technical Fellow
| CCSP CISSP CISM

Do you remember your password?

The image displays three overlapping screenshots of a Microsoft account's 'Security info' page. The top-left screenshot shows the account for Ronny de Jong (ronnydejong@microsoft.com) with a sidebar menu including Overview, Security info (selected), Devices, and Password. The middle screenshot shows the account for Jan Bakker (jan.bakker@janbakkerconsultir) with a similar sidebar menu. The rightmost screenshot is a detailed view of the 'Security info' page for Jan Bakker, showing the 'Default sign-in method' as 'Phone - text +31 0643941043' and a list of sign-in methods. The 'Password' method is highlighted with a red rectangle, showing it was 'Last updated: 4 years ago'.

Ronny de Jong
ronnydejong@microsoft.com

Overview
Security info
Devices
Password

Security info
These are the methods you use to sign into your account or reset your password

You're using the following sign-in method when you log in:

+ Add sign-in method

... Password Last updated: 4 years ago

Jan Bakker
jan.bakker@janbakkerconsultir

Overview
Security info
Devices
Password
Organizations
Settings & Privacy

Security info
These are the methods you use to sign into your account or reset your password

Default sign-in method: Phone - text +31 0643941043 [Change](#)

+ Add sign-in method

... Password Last updated: 4 years ago



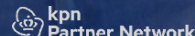
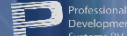
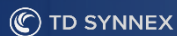
Let's talk passkeys



Based on **FIDO** standards, passkeys are a **replacement** for **passwords** that provide **faster**, **easier**, and **more** secure sign-ins to websites and apps across a user's devices. Unlike passwords, passkeys are always strong and **phishing-resistant**.

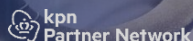
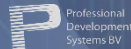
fidoTM ALLIANCE

Founded in 2013





Experts Live Netherlands



FIDO2 (security)keys can store passkeys

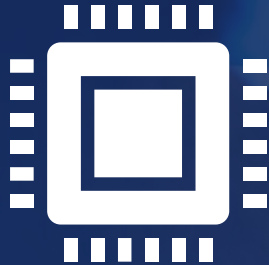


Passwords keys

FIDO? standard



Authenticator types



Platform Authenticator

Touch ID

Face ID

Windows Hello



Roaming Authenticator

Security keys

(USB/NFC/BTE)

Most of your
users already
carry a platform
authenticator in
their pockets
every day





Faster & Easier



More Secure



Passkey are built on PKI



Phishing Resistant



How passkeys work (Registration)

Authenticator



PIN or
Biometrics

RP ID	Priv	Pub
Contoso.com		

Client

Relying Party

I want to create a new passkey for
user A

Sure, here's a challenge

Please make a new keypair for **contoso.com**

Here's the public key. I'll hold on to
the private key

Here's the public key and the origin
challenge

I've linked the public key to **user A**.
See you next time!



User	Pub
User A	



8 5 8

voer deze code in jouw app in

No more **passwords**
No more **shared secrets**
No more **AiTM attacks**



Where do we store our passkeys?







Device-bound passkeys

Bound to and used only on a single device

Synced passkeys

Stored securely in a credential manager and accessed across devices

Device-bound passkeys

Bound to a FIDO security key or platform and cannot be synced across devices.



Device-bound passkeys

Bound to a FIDO security key or platform and cannot be synced across devices.



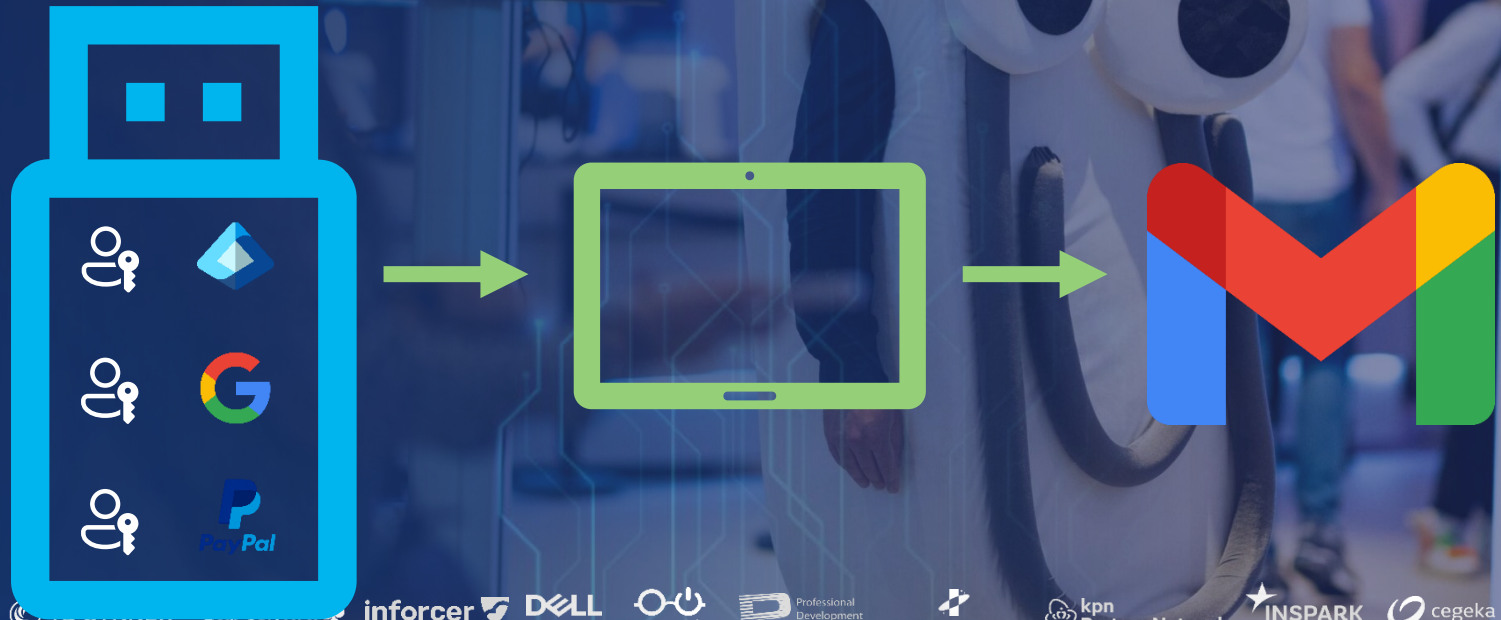
Device-bound passkeys

Bound to a FIDO security key or platform and cannot be synced across devices.



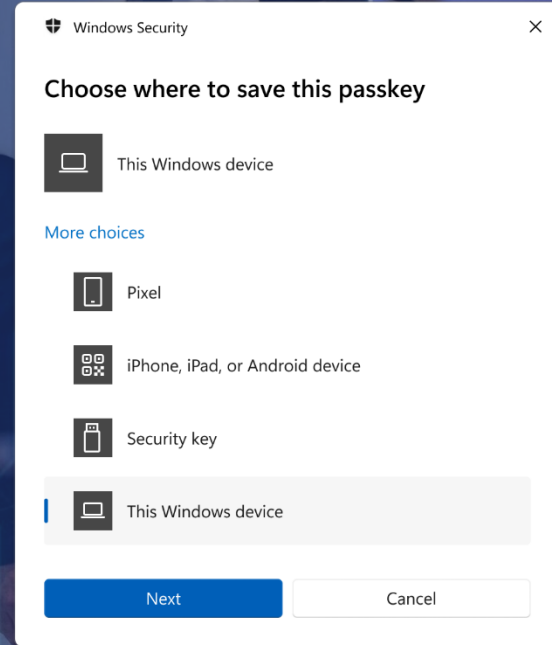
Device-bound passkeys

Bound to a FIDO security key or platform and cannot be synced across devices.



Support for passkeys in Windows

Linked device (**Android only**)
iPhone, iPad or Android device (**cross device via QR code**)
Security key (**USB** or **NFC**)
Local (**Windows Hello**)



Passkeys for any
supported services
may already land on
your **corporate**
devices today.



Settings



Jan Bakker

Find a setting

System

Bluetooth & devices

Network & internet

Personalization

Apps

Accounts

Time & language

Gaming

Accessibility

Privacy & security

Windows Update

Accounts > Passkeys

Use the passkeys saved on this device to sign in to apps and websites without a password. Instead, your passkeys allow you to sign in using your face, fingerprint, or PIN through Windows Hello.

Saved passkeys

Search passkeys

9 apps and websites found

Sort by: Name (Z to A)

passkey.org	Jan	...
login.microsoft.com		...
login.microsoft.com		...
login.microsoft.com		...
login.microsoft.com		...
login.microsoft.com		...
login.microsoft.com		...
google.com		...



Synced passkeys

Stored securely in a credential manager and accessed across devices.



Synced passkeys

Stored securely in a credential manager and accessed across devices.



Synced passkeys

Stored securely in a credential manager and accessed across devices



Passkey in Microsoft Authenticator App



- Lives in the Authenticator App
- Cannot leave the device
- Can be used cross-device
- Runs on iOS and Android

How to enable passkeys in Entra ID?





MC920300 - Microsoft Entra: Enablement of Passkeys in Authenticator for passkey (FIDO2) organizations with no key restrictions

Message ID

MC920300[View in Message Center](#)

Service

Microsoft Entra

Last Updated

Jan 24, 2025

Published Oct 28, 2024

Tag

Major change

Updated message

Admin impact

Act by

Mar 3, 2025

Summary

Starting late January 2025, organizations with enabled passkey (FIDO2) policy and no key restrictions will have passkeys in the Microsoft Authenticator app. Users can add this via [aka.ms/MySecurityInfo](#), and it's enforced by Conditional Access policy. Organizations preferring not to enable this can impose key restrictions.

More information

Beginning late January 2025 (previously mid-January), after the General Availability of passkeys in the Microsoft Authenticator app, organizations with the passkey (FIDO2) authentication methods policy enabled with no key restrictions will be enabled for passkeys in the Microsoft Authenticator app in addition to FIDO2 security keys. This update aligns with the broader availability of passkeys in Entra ID, extending from device-bound passkeys on security keys to device-bound passkeys also on user devices. Users who navigate to [aka.ms/MySecurityInfo](#) will see "Paskey in Microsoft Authenticator" as an authentication method they can add. Additionally, when Conditional Access (CA) authentication strengths policy is used to enforce passkey authentication, users who don't yet have any passkey will be prompted inline to register passkeys in Authenticator to meet the CA requirements. If an organization prefers not to enable this change for their users, they can work around it by enabling key restrictions in the passkey (FIDO2) policy. This change will not impact organizations with existing key restrictions or organizations that have not enabled the passkey (FIDO2) policy.

When this will happen:

General Availability (Worldwide, GCC, GCC High, DoD): Rollout will happen late January 2025 (previously mid-January).

How this will affect your organization:

Microsoft Entra admin center

Search resources, services, and docs (G+/)

Copilot

admin@M365x341716...
CONTOSO (M365X341716.ONMIC...

Home

What's new

Diagnose & solve problems

Favorites

Identity

Overview

Users

Groups

Devices

Applications

Protection

Identity Governance

External Identities

Show more

Protection

Identity Protection

Conditional Access

Authentication methods

Password reset

Learn & support

Home >

Authentication methods | Policies

Contoso - Microsoft Entra ID Security

Search

<<

+ Add external method (Preview)

Refresh

Got feedback?

Manage

Policies

Password protection

Registration campaign

Authentication strengths

Settings

Monitoring

Activity

User registration details

Registration and reset events

Bulk operation results

Migration status

Complete (change)

Method	Target	Enabled
Passkey (FIDO2)	All users	Yes
	All users	Yes
SMS	All users	Yes
Temporary Access Pass	All users	Yes
Hardware OATH tokens (Preview)	All users	Yes
Third-party software OATH tokens		No
Voice call		No
Email OTP		No
Certificate-based authentication		No

Microsoft Entra admin center

Search resources, services, and docs (G+/)

Copilot

1

admin@M365x341716...
CONTOSO (M365X341716.ONMIC...

Home

What's new

Diagnose & solve problems

Favorites

Identity

Overview

Users

Groups

Devices

Applications

Protection

Identity Governance

External Identities

Show more

Protection

Identity Protection

Conditional Access

Authentication methods

Password reset

Learn & support

Home > Authentication methods | Policies >

Passkey (FIDO2) settings ...

Passkeys are a phishing-resistant, standards-based passwordless authentication method available from a variety of vendors. [Learn more](#).

Passkeys are not usable in the Self-Service Password Reset flow.

Enable and Target

Configure

GENERAL

Allow self-service set up

YesNo

Enforce attestation

YesNo

KEY RESTRICTION POLICY

Enforce key restrictions

YesNo

Restrict specific keys

AllowBlock

Microsoft Authenticator ⓘ

Add AAGUID

90a3ccdf-635c-4729-a248-9b709135078f

de1e552d-db1d-4423-a619-566b625cdc84

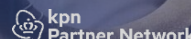
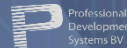
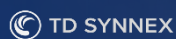


Experts Live Netherlands

8 5 8

voer deze code in jouw app in

AAGUID



Challenge response

Installing Yubico Software on Linux

Getting Started on iOS

macOS Login Tool Configuration Guide
[Deprecated]

YubiKey PIV Manager User's Guide
[deprecated]

Using your YubiKey as a smart card in
macOS

Can I duplicate a YubiKey?

Using a YubiKey with USB-C Adapters

Code Signing with the YubiKey on Windows

YubiCloud OTP Validation Service Guide

YubiKey for YubiCloud Configuration Guide

OATH-HOTP: Yubico Best Practices Guide

Achieving FedRamp Compliance with the
YubiKey FIPS Series Devices

Using Your YubiKey with Keeper

Setting the NDEF Slot for NFC Usage

Windows Logon Tool & Configuration
Guide [Deprecated]

Generating Base32 string examples

FIDO U2F Security Key (U2F)

YubiKey 4 (Series)	All	N/A	N/A
YubiKey FIPS (4 Series)	4.4	N/A	N/A
YubiKey 5 Series			
YubiKey 5 (USB-A, No NFC)	5.1	cb69481e-8ff7-4039-93ec-0a2729a154a8	Level 1
YubiKey 5 (USB-A, No NFC)	5.2, 5.4	ee882879-721c-4913-9775-3dfcce97072a	Level 1
YubiKey 5 NFC	5.1	fa2b99dc-9e39-4257-8f92-4a30d23c4118	Level 1
YubiKey 5 NFC	5.2, 5.4	2fc0579f-8113-47ea-b116-bb5a8db9202a	Level 1
YubiKey 5 NFC	5.7	a25342c0-3cdc-4414-8e46-f4807fca511c d7781e5d-e353-46aa-afe2-3ca49f13332a	Level 2
YubiKey 5C NFC	5.2, 5.4	2fc0579f-8113-47ea-b116-bb5a8db9202a	Level 1
YubiKey 5C NFC	5.7	a25342c0-3cdc-4414-8e46-f4807fca511c d7781e5d-e353-46aa-afe2-3ca49f13332a	Level 2
YubiKey 5 Nano	5.1	cb69481e-8ff7-4039-93ec-0a2729a154a8	Level 1
YubiKey 5 Nano	5.2, 5.4	ee882879-721c-4913-9775-3dfcce97072a	Level 1
YubiKey 5 Nano	5.7	19083c3d-8383-4b18-bc03-8f1c9ab2fd1b ff4dac45-ede8-4ec2-aced-cf66103f4335	Level 2
YubiKey 5C Nano	5.1	cb69481e-8ff7-4039-93ec-0a2729a154a8	Level 1
YubiKey 5C Nano	5.2, 5.4	ee882879-721c-4913-9775-3dfcce97072a	Level 1
YubiKey 5C Nano	5.7	19083c3d-8383-4b18-bc03-8f1c9ab2fd1b ff4dac45-ede8-4ec2-aced-cf66103f4335	Level 2
YubiKey 5C	5.1	cb69481e-8ff7-4039-93ec-0a2729a154a8	Level 1
YubiKey 5C	5.2, 5.4	ee882879-721c-4913-9775-3dfcce97072a	Level 1
YubiKey 5C	5.7	19083c3d-8383-4b18-bc03-8f1c9ab2fd1b ff4dac45-ede8-4ec2-aced-cf66103f4335	Level 2
YubiKey 5Ci	5.2, 5.4	c5ef55ff-ad9a-4b9f-b580-adebaf026d0	Level 1
YubiKey 5Ci	5.7	a02167b9-ae71-4ac7-9a07-06432ebb6f1c 24673149-6c86-42e7-98d9-433fb5b73296	Level 2

Security Advisory YSA-2024-03

Security Advisory YSA-2024-03 Infineon ECDSA Private Key Recovery

Published Date: 2024-09-03

Tracking IDs: YSA-2024-03

CVE: In Process

CVSS Severity: [4.9](#)

Summary

A vulnerability was discovered in Infineon's cryptographic library, which is utilized in YubiKey 5 Series, and Security Key Series with firmware prior to 5.7.0 and YubiHSM 2 with firmware prior to 2.4.0. The severity of the issue in Yubico devices is moderate.

An attacker could exploit this issue as part of a sophisticated and targeted attack to recover affected private keys. The attacker would need physical possession of the YubiKey, Security Key, or YubiHSM, knowledge of the accounts they want to target, and specialized equipment to perform the necessary attack. Depending on the use case, the attacker may also require additional knowledge including username, PIN, account password, or authentication key. See Affected Use Cases and Mitigations for more details.

Files

main

Go to file

Entra

Export-Fido2Info.ps1

Scripts / Entra / Export-Fido2Info.ps1

MichelmanVliet Update Export-Fido2Info.ps1

25d8d6c · 11 months ago

History

Code

Blame

130 lines (110 loc) · 4.72 KB

Raw



```
1 <#
2 .SYNOPSIS
3     Export all FIDO2 registration info for all users within an Entra OD tenant
4
5 .DESCRIPTION
6     PowerShell script to gather and export all FIDO2 registration information for all users to a .CSV file.
7
8 .NOTES
9     Requirements:
10    - Microsoft Graph Powershell SDK (will be installed if not present)
11    - Graph permissions:
12      User.Read.All
13      UserAuthenticationMethod.Read.All
14      UserAuthMethod-Passkey.Read.All
15
16 .PARAMETER CsvFile
17     Specify the full output path and filename for the CSV report file.
18     If not specified, the script will produce a report in the current folder using the following file name: "Fido2Registration_Report.csv".
19
20 .PARAMETER Delimiter
21     Specify the delemiter character used for the CSV output file.
22     If not specified, ";" will be used as delimiter.
23
24 .EXAMPLE
25     PS> .\Export-Fido2Info.ps1 -CsvFile "C:\Temp\Fido2Registration_Report.csv" -Delimiter ";"
26
27
```



8 5 8

voer deze code in jouw app in

Passkey enrollment



MFA is required for enrollment of strong auth methods

Security key

Windows Hello for Business

Passkey in Auth App





Temporary Access Pass





8 5 8

voer deze code in jouw app in

"The easiest and fastest way to add a passkey is to add it directly in the Authenticator app."

Register passkey in Authenticator App with Temporary Access Pass



Microsoft



TD SYNEX

Capgemini

infor

DELL
Technologies

nerdio

P

Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network

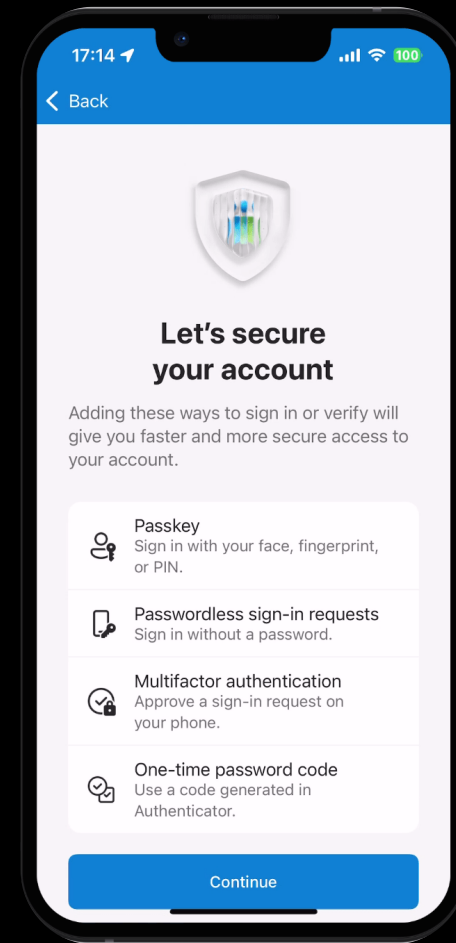


INSPIRE



cegeka

All the methods!



Microsoft

TD SYNnex

Capgemini

infor

DELL
Technologies

nerdio

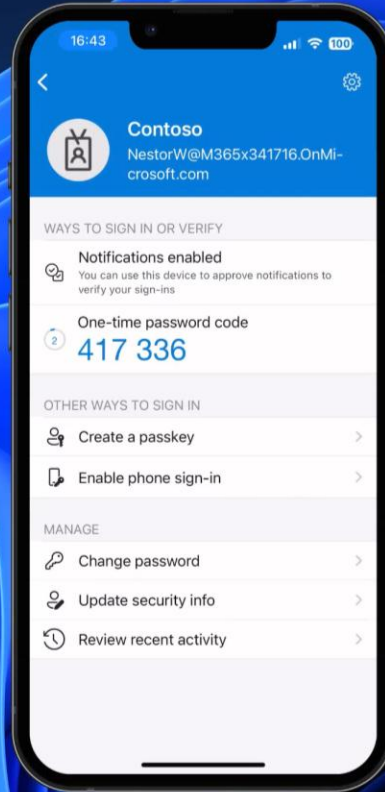
P Professional
Development
Systems BV

INTERSTELLAR

kpn
Partner Network

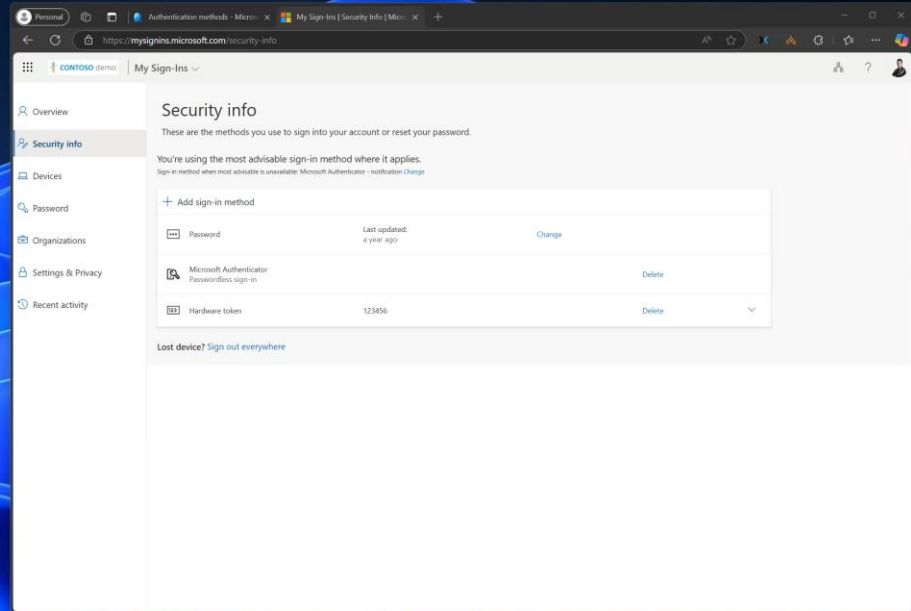
INS PARK

cegeka

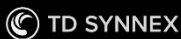


Register passkey for existing users with MFA

Cross-device registration of passkeys



Microsoft



TD SYNnex



Capgemini



inforcenter



DELL
Technologies



nerdio



Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network



INSPIRE



cegeka

Overview

Security info

Devices

Password

Organizations

Settings & Privacy

Recent activity

Security info

These are the methods you use to sign into your account or reset your password.

You're using the most advisable sign-in method where it applies.

Sign-in method when most advisable is unavailable: Microsoft Authenticator - notification [Change](#)

+ Add sign-in method

*** Password

Last updated:
a year ago

[Change](#)

Microsoft Authenticator
Passwordless sign-in

123 Hardware token

Lost device? [Sign out](#)

Passkey not accepted



Delete this passkey in your Microsoft Authenticator app, then return here to create a new one. You'll need to sign in to Authenticator again with your admin@M365x341716.onmicrosoft.com account.

[Having trouble?](#)

OK

Attestation not supported
using the WebAuthN flow

No resource was found matching this query

Request body Request headers Modify permissions Access token

OK - 200 - 470 ms

Response preview Response headers Code snippets Toolkit component Adaptive cards

```
{
  "@odata.context": "https://graph.microsoft.com/beta/$metadata#users('90f43eac-70c3-4aa7-bcca-7ee3522b3845')/authentication/fido2Methods",
  "@microsoft.graph.tips": "Use $select to choose only the properties your app needs, as this can lead to performance improvements. For example: GET users('<guid>')/authentication/fido2Methods?$select=attestationCertificates",
  "value": [
    {
      "id": "4IHwPDQyTkO0C6t7DT9B7A2",
      "displayName": "Authenticator - iOS",
      "createdDateTime": "2025-01-30T21:00:05Z",
      "aaGuid": "90a3ccdf-635c-4729-a248-9b709135078f",
      "model": "Microsoft Authenticator - iOS",
      "attestationCertificates": [],
      "attestationLevel": "attested"
    },
    {
      "id": "t3gCeWN4Q0mKuyB4miQkNg2",
      "displayName": "Authenticator - iOS",
      "createdDateTime": "2025-01-30T20:44:31Z",
      "aaGuid": "90a3ccdf-635c-4729-a248-9b709135078f",
      "model": "Microsoft Authenticator - iOS",
      "attestationCertificates": [],
      "attestationLevel": "notAttested"
    }
  ]
}
```



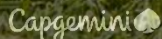

All set. Now let's **use** it!



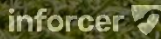
Microsoft



TD SYNEX



Capgemini



inforcenter



DELL
Technologies



nerdio



Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network



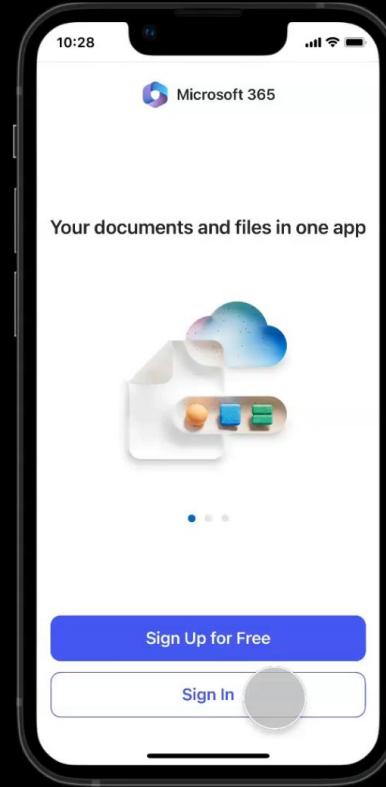
INS PARK



cegeka



Same device sign-in



Microsoft



TD SYNnex



Capgemini



inforcenter



DELL
Technologies



nerdio



Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network



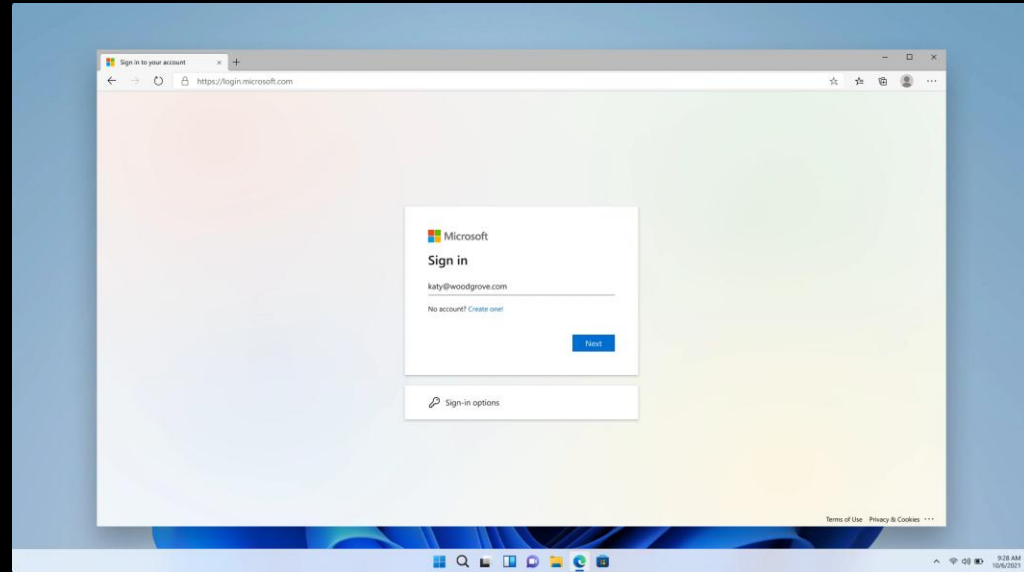
INS PARK



cegeka

Cross device sign-in

This sign-in option requires Bluetooth and an internet connection for both devices



What does **not** work today?

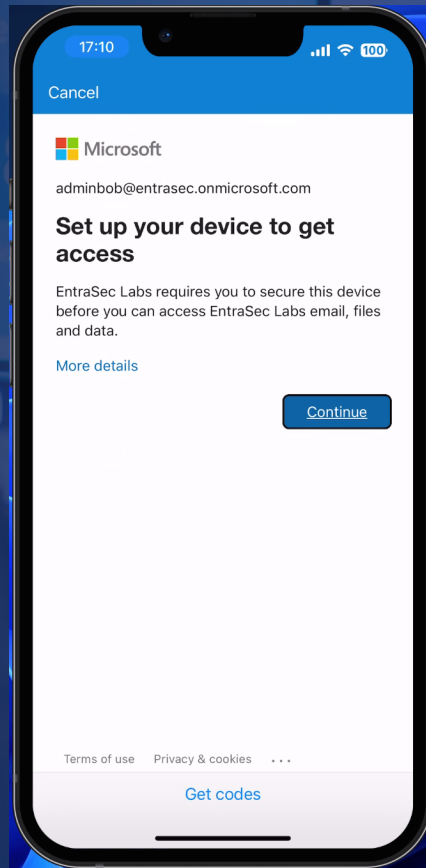
Store Entra ID passkeys in other credential providers like 1Password or Google Authenticator

Store 3rd party passkeys in Microsoft Authenticator

Sync passkeys from Entra ID to other devices

Conditional Access
doing its job

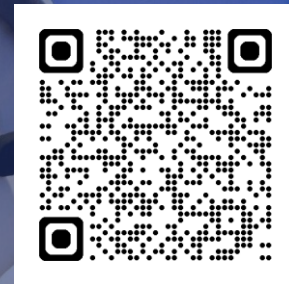
All resources (formerly
'All cloud apps')



- ☐ Require multifactor authentication ⓘ
- ☐ Require authentication strength ⓘ
- ☐ Require device to be marked as compliant ⓘ
- ☐ Require Microsoft Entra hybrid joined device ⓘ
- ☐ Require approved client app ⓘ
[See list of approved client apps](#)
- ☐ Require app protection policy ⓘ
[See list of policy protected client apps](#)
- ☐ Require password change ⓘ

For multiple controls

- ☒ Require all the selected controls
- ☐ Require one of the selected controls



Learn how!



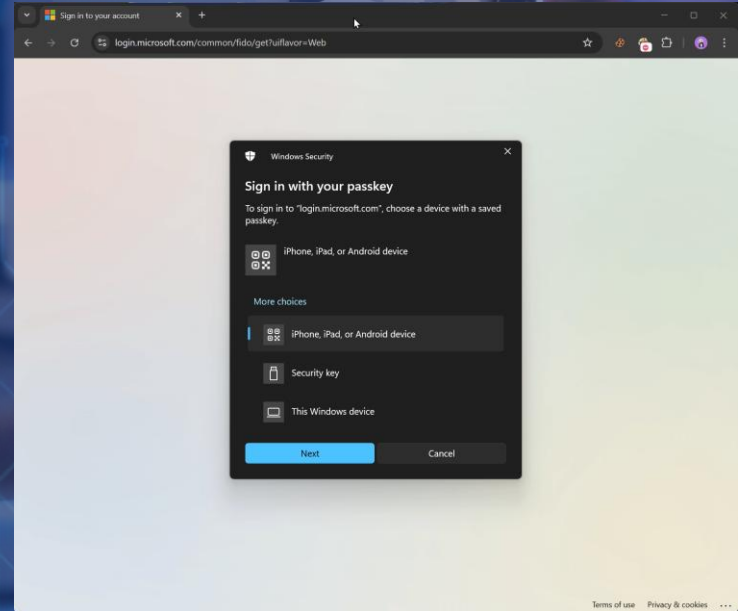
Passkey provisioning

(only supported for hardware security keys)

Enforce PIN complexity and change on first use

```
PowerShell
Do you want to proceed with the above configuration? [y/N]: y
YubiKey will be factory reset. ANY EXISTING CREDENTIALS WILL BE LOST!
Remove the YubiKey from the USB port...
Re-insert the YubiKey...
Touch the YubiKey...
The YubiKey has been reset.
Creating credential on YubiKey...
Touch the YubiKey...
Credential created on YubiKey!
Registering credential with identity provider...
New credential registered!

YubiKey configuration summary:
Serial number: 33073988
Temporary PIN: 208624
NOTE: The PIN needs to be changed before it can be used!
PS C:\Program Files\Yubico\YubiEnroll> |
```





Are we there yet?

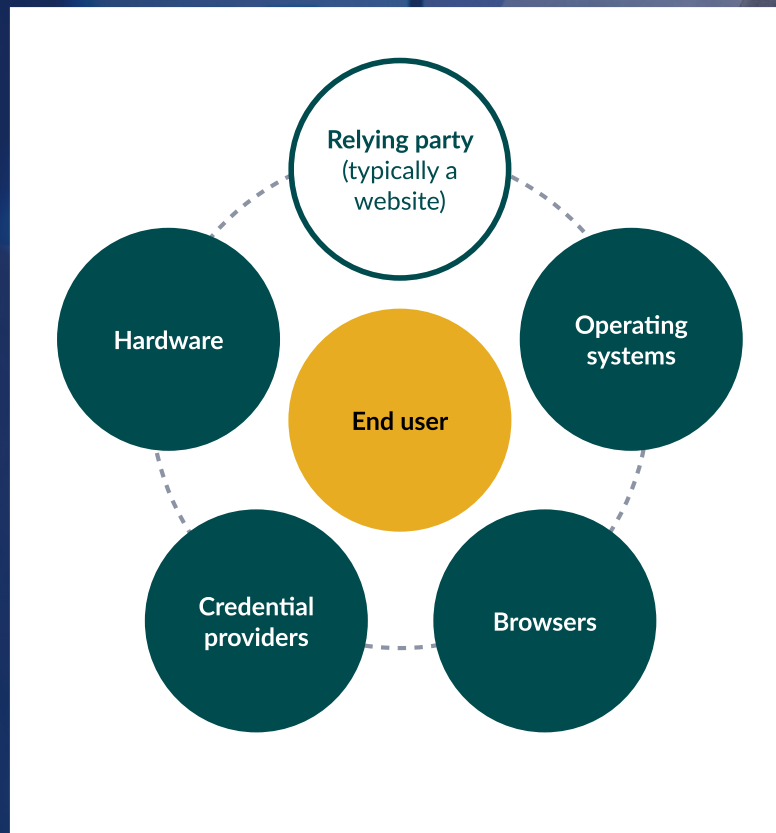




We are still in
the early stage
of passkeys



The API is there.....



Android struggles

I'm on an Android 14 device, and I followed all the steps. Why can't I register passkeys in the Authenticator app?

The Authenticator app uses [Android APIs](#) on Android 14 or higher to use passkeys. Manufacturers choose whether or not to implement these APIs for each device they make. If your device doesn't support these APIs, the Authenticator app might not work for your device on Android 14. For the best experience, we recommend that you upgrade to Android 15.



Android struggles cont'd

Store passkeys in Android profiles

Passkeys on Android are used only from the profile where they're stored. If a passkey is stored in an Android Work profile, it's used from that profile. If a passkey is stored in an Android Personal profile, it's used from that profile. To make sure that users can access and use the passkey they need, users with both an Android Personal profile and an Android Work profile should **create their passkeys in Authenticator for each profile.**

Android struggles still cont.'s

Why do I get prompted for PIN instead of biometric sign-in on my Android device?

If biometric sign-in fails on an Android device, the Authenticator app will prompt you to enter your PIN instead. The next time you sign in with the passkey, Authenticator continues to request the PIN rather than biometric sign-in. Authenticator periodically retries biometric sign-in. If biometric sign-in succeeds, it will be used for subsequent sign-ins.

What happens to my passkey after I change my PIN or biometric sign-in on my Android device?

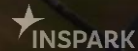
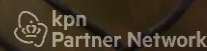
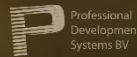
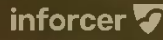
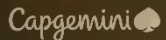
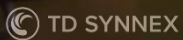
Your passkey is invalidated if you change your PIN, or if you change your biometric sign in from thumbprint to face, or vice-versa. If your passkey is invalidated, you need to sign-in by using a different method, and then create a new passkey.





Lack of **scoping** and **profiles**

Currently one policy to rule them all.....



**End-user
confusion**



Overview

Security info

Devices

Password

Organizations

Settings & Privacy

Recent activity

Security info

These are the methods you use to sign into your account or reset your password.

You're using the most advisable sign-in method v

Sign-in method when most advisable is unavailable: Microsoft Authentica

+ Add sign-in method

... Password

Microsoft Authenticator
Passwordless sign-in

123 Hardware token

Passkey
Microsoft Authenticator

Lost device? [Sign out everywhere](#)

Add a sign-in method



Passkey in Microsoft Authenticator

Sign in with your face, fingerprint, PIN



Security key or passkey

Sign in with your face, fingerprint, PIN or security key



Security key

Sign in using a USB, Bluetooth, or NFC device



Microsoft Authenticator

Approve sign-in requests or use one-time codes



Hardware token

Sign in with a code from a hardware token



Phone

Get a call or text to sign in with a code



Email

Receive a code to reset your password



Windows Security



Sign in with your passkey

To sign in to "login.microsoft.com", choose a device with a saved passkey.



iPhone, iPad, or Android device

More choices



iPhone, iPad, or Android device



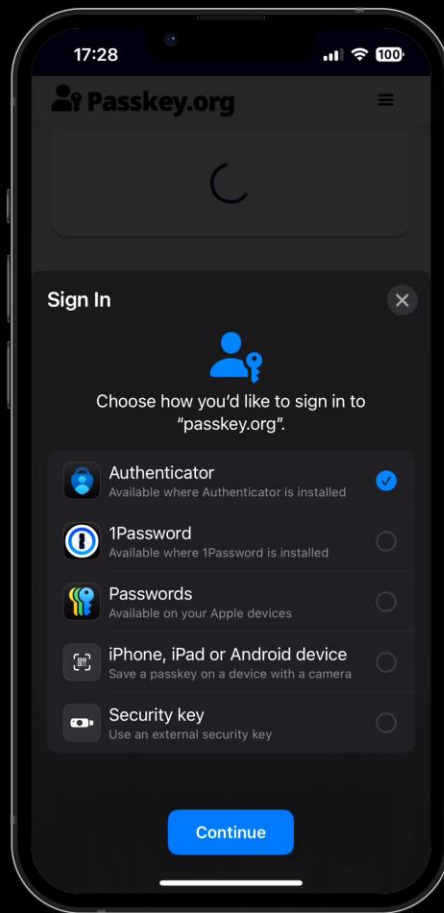
Security key



This Windows device

Next

Cancel



Microsoft



TD SYNnex



Capgemini



inforcenter



DELL
Technologies



nerdio



Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka



Strengthen onboarding & recovery process



Trusted
device



Trusted
location



Temporary
Access Pass



Microsoft



TD SYNnex



Capgemini



infor



Dell
Technologies



nerdio



Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka

CONTOSO demo | My Access | Search packages by name, description or resources

Christian Horner
Christian.Horner@m365x3...

- Overview
- Access packages**
- Request history
- Approvals
- Access reviews
- My Account
- My Apps
- My Groups
- Give feedback

Access packages

Access groups and teams, SharePoint sites, applications, and more in a single package. Select from the following packages, or search to find what you're looking for.

Available (2) Active (0) Expired (0)

Name ↑	Description	Resources	Actions
Exchange Admin Role	Request Exchange Admin Role	Exchange Administrator	Request
Temporary Access Pass	Temporary Access Pass		Request

Request
Temporary
Access Pass
on behalf of
users



Inform end-users of changes in authentication methods



Microsoft



TD SYNnex

Capgemini

infor

DELL
Technologies

nerdio

P

Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network



INS PARK



cegeka



New passkey added to your account



If you didn't add a passkey, someone might be using your account. Check and secure your account now.

[Check activity](#)

You can also see security activity at
<https://myaccount.google.com/notifications>

You received this email to let you know about important changes to your Google Account and services.

© 2025 Google Ireland Ltd., Gordon House, Barrow Street, Dublin 4, Ireland



<https://janbakker.tech/microsoft-365-end-user-notifications-for-changes-in-authentication-methods/>



Start today!



Microsoft



TD SYNEX

Capgemini



infor



DELL
Technologies

nerdio



Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network



INSPIRE



cegeka

IT pros/DevOps workers

Considerations for specific **personas** in a phishing-resistant passwordless authentication deployment in Microsoft Entra ID

Locked down devices with Bluetooth disabled

Issue USB security keys and/or smart cards?

Wide variety of RDP, SSH, PAM, etc. use cases

Integrate non-domain joined servers with Microsoft Entra ID RDP and SSH. Mandate smart card authentication for domain-joined servers?

Multiple Accounts

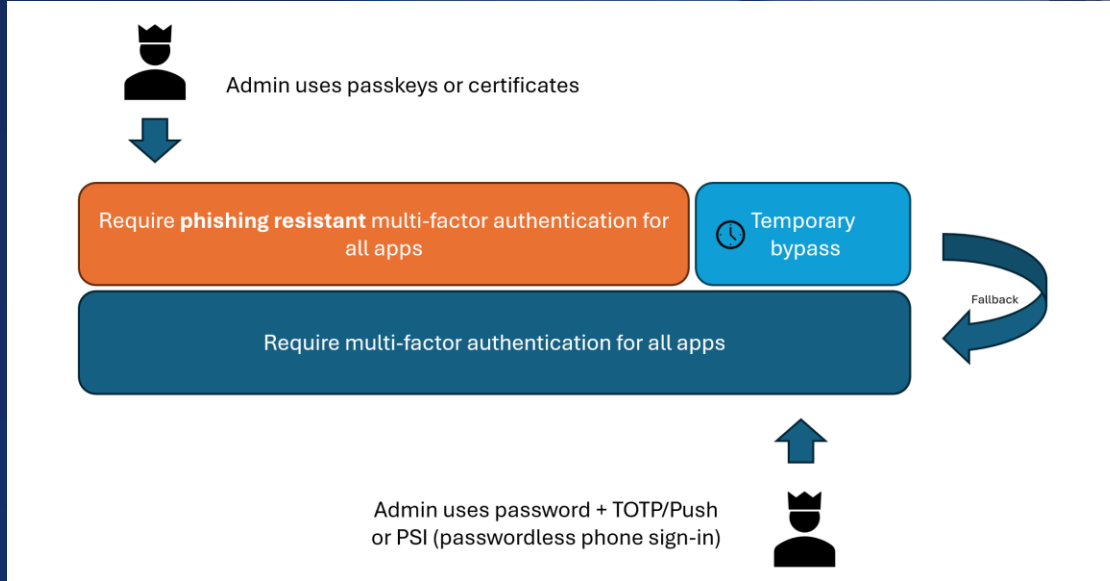
Issue USB security keys that can hold multiple FIDO and smart card identities?

Authenticating scripts with user service accounts

Switch to running scripts with service principals?

<https://learn.microsoft.com/en-us/entra/identity/authentication/how-to-plan-persona-phishing-resistant-passwordless-authentication#frontline-workers>

Entra/Azure Admins should be phishing resistant by now



<https://janbakker.tech/temporary-exclusions-for-conditional-access-using-pim-for-groups/>

Passkey enrolled? Enforce it!

Microsoft Entra admin center

Search resources, services, and docs (G+/I)

admin@entrasec.onmic
ENTRASEC LABS ENTRASEC ON

Home > EntraSec Labs > Conditional Access

Conditional Access | Authentication strengths

Microsoft Entra ID

Overview Policies Insights and reporting Diagnose and solve problems

Manage

- Named locations
- Custom controls (Preview)
- Terms of use
- VPN connectivity
- Authentication contexts
- Authentication strengths**
- Classic policies

Monitoring

- Sign-in logs
- Audit logs

Troubleshooting + Support

- New support request

Authentication strengths determine the combination of authentication methods that can be used to sign in.

Learn more

Type: All Authentication methods: All Reset filters

Authentication strength	Type	Authentication methods
Multifactor authentication	Built-in	Windows Hello For Business and 1
Passwordless MFA	Built-in	Windows Hello For Business and 3
Phishing-resistant MFA	Built-in	Windows Hello For Business and 2

View Authentication Strength

Name: Phishing-resistant MFA

Type: Built-in

Description: Include authentication methods that are phishing-resistant like Passkeys (FIDO2) and Windows Hello for Business

Authentication Flows

Windows Hello For Business

OR

Passkeys (FIDO2)

OR

Certificate-based Authentication (Multifactor)



Chicken & egg problem



Conditional Access

Authentication Strengths

Policy	Target	Device Platforms	Grant control – Custom Authentication Strength	AAGUIDS
Bootstrap & Recovery policy	Register security information	N/A.	Password + Microsoft Authenticator (Push Notification) OR Temporary Access Pass (One-time use) OR Temporary Access Pass (Multi-use)	N/A.
Secure Desktop Apps	All resources	Exclude: iOS Android	Passkeys (FIDO2)*	Microsoft Authenticator (iOS) Microsoft Authenticator (Android)
Secure Mobile Apps	All resources	Include: iOS Android	Passkeys (FIDO2) OR Temporary Access Pass (One-time use) OR Temporary Access Pass (Multi-use)	Microsoft Authenticator (iOS) Microsoft Authenticator (Android)

<https://janbakker.tech/you-shall-not-passkey/>

Avoid Authentication strength Conditional Access policy loops

Use different strengths for desktop and mobile

To avoid costs, first register, then enforce

Test all use cases, not just the happy flow

Have proper guidance for your users

What have we learned today?

Passkeys are not new

Passkey will replace passwords

We're just getting started

We really need passkey profiles!

Enrollment can be hard. Auth app first!

End-users need guidance

Think persona-based

Have different passkeys for different platforms

Get started ASAP



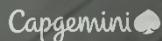
Questions?



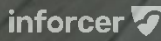
Microsoft



TD SYNnex



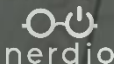
Capgemini



inforcenter



DELL
Technologies



nerdio



Professional
Development
Systems BV



INTERSTELLAR



kpn
Partner Network



INSPIRE



cegeka



Please evaluate this session in the App.

THANK YOU

Are there any questions?





Next session 13:00 – 13:50

**Cyber Deception : A story about honeypots and
canaries by Fabian Bader**

